

Harbor + Terraform + CI sécurisée

Objectif : déployer un registre d'images privé (Harbor) par Infrastructure as Code, sécuriser sa chaîne de livraison, et la rendre observable.

1 IaC

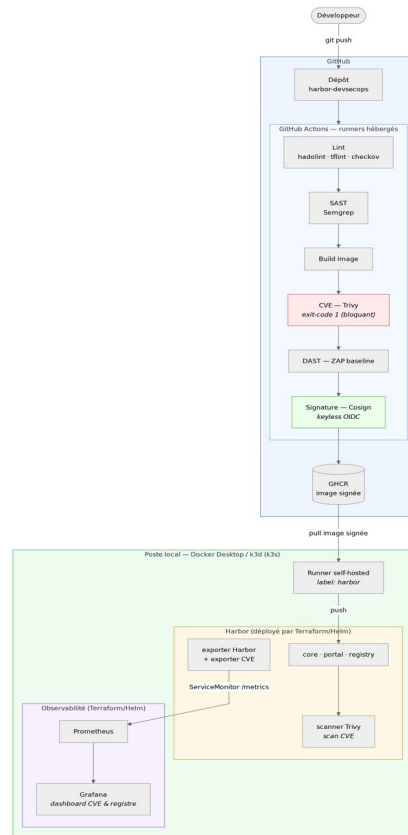
Terraform + Helm sur k3s

2 CI sécurisée

lint·SAST·CVE·DAST·signature

3 Observabilité

Prometheus + Grafana



PILIER 1

Infrastructure as Code

k3s / k3d

le cluster Kubernetes léger (k3s lancé dans Docker via k3d)

Helm

le gestionnaire de paquets : installe les applications via des charts

Terraform

l'orchestrateur : pilote Helm pour déployer Harbor + la surveillance

Déploiement

```
terraform init
terraform plan
terraform apply
→ Harbor + monitoring déployés
```

À dire : « Terraform pilote Helm pour installer Harbor et la surveillance sur k3s. Une commande, infra reproductible et versionnée. »

Pipeline CI sécurisée (bloquante)

1

Lint

hadolint·tflint·checkov

2

SAST

Semgrep — code au repos

3

CVE

Trivy — exit-code 1
(bloquant)

4

DAST

ZAP — appli en exécution

5

Signature

Cosign keyless

Runner self-hosted : le dernier job pousse l'image dans Harbor (local) — les runners cloud ne peuvent pas l'atteindre, d'où un runner sur ma machine.

À dire : « 5 portes de sécurité ; si une échoue (ex. Trivy, exit-code 1), la livraison est bloquée. »

Observabilité

1. Harbor

expose ses métriques + scanne (Trivy)

2. ServiceMonitor

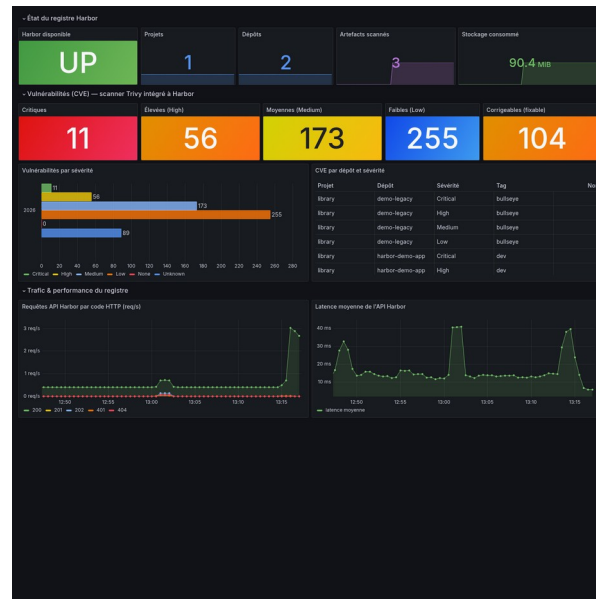
dit à Prometheus de collecter (CRD)

3. Prometheus

collecte et stocke les métriques

4. Grafana

affiche le dashboard Register & CVE



À dire : « Un exporter maison interroge l'API Harbor pour exposer les CVE par sévérité — c'est la source du dashboard. »

Bilan & réflexes

Livré

Harbor par Terraform + pipeline CI bloquante verte + dashboard CVE

Réflexe 1

SAST = statique (code) · DAST = dynamique (appli en exécution)

Réflexe 2

« Bloquant » = Trivy exit-code 1 sur CVE HIGH/CRITICAL corrigéables

Réflexe 3

Runner self-hosted : Harbor est local, injoignable depuis le cloud

Réflexe 4

depends_on : Prometheus avant Harbor (CRD ServiceMonitor)